

1. Scopo e ambito di applicazione

Il presente registro raccoglie gli incidenti significativi e gravi ai sensi degli artt. 24 e 25 del D.Lgs. 138/2024 che hanno coinvolto i sistemi di rete e informativi di Toscana Diagnostica S.r.l. È tenuto dal Punto di Contatto NIS, con il supporto del RSGI, in attuazione della TD-SGI-PRO070_00 §6.

Sono iscritti tutti gli eventi qualificati come incidente significativo o grave dalla matrice di significatività della PRO070, comprensivi di near miss e di esercitazioni tabletop. Gli eventi minori (eventi indesiderati ICT non significativi) restano tracciati nel registro generale di TD-SGI-PRO019.

Il registro è conservato per almeno 6 anni dalla chiusura dell'incidente, in coerenza con la prescrizione decennale degli illeciti amministrativi rilevanti ex D.Lgs. 138/2024 e con i requisiti di accountability del SGI.

2. Riferimenti

Riferimento	Ambito
D.Lgs. 138/2024 artt. 24-25	Obblighi MTOM, notifica e classificazione incidenti
Determinazione ACN n. 38565/2025	Tassonomia incidenti, format notifiche
TD-SGI-PRO070_00	Procedura NIS2, catena di risposta a 5 fasi
TD-SGI-MOD184_00	Checklist Notifiche NIS2 (T0+24h, T0+72h, T0+30gg)
TD-SGI-IDL026_00	Trasmissione operativa al Portale ACN
TD-SGI-PRO019_00	Gestione eventi indesiderati ICT (eventi non NIS-significativi)

3. Tassonomia degli incidenti (estratto operativo)

La tassonomia operativa è ridotta dall'allegato della Determinazione ACN n. 38565/2025 e si applica per la classificazione iniziale.

Categoria	Esempi
Indisponibilità di servizio	Outage di LIS/RIS/PACS, downtime > soglia, attacco DDoS
Compromissione di confidenzialità	Esfiltrazione dati pazienti, accesso non autorizzato a referti
Compromissione di integrità	Alterazione di referti, manipolazione dati di QC, modifiche ai workflow LIS
Malware / ransomware	Cifratura sistemi clinici, lateral movement, encryption di backup
Phishing/social engineering	Furto credenziali con impatto su sistemi NIS-soggetti
Supply-chain compromise	Compromissione fornitore ICT critico (es. provider LIS, datacenter)
Errore configurazione/umano	Misconfigurazione che esponga dati o servizi
Evento fisico	Furto/sottrazione di dispositivi contenenti dati clinici

4. Tabella Registro Incidenti

Compilare per ogni incidente significativo o grave. Le evidenze dettagliate (log, screenshot, comunicazioni con CSIRT/ACN, RCA, CAPA) sono archiviate in un fascicolo dedicato collegato all'identificativo dell'incidente.

#	Voce	Esempio compilazione
---	------	----------------------

TD-SGI-MOD181_00 - Rev. 00 - Registro degli Incidenti Significativi NIS2

1	ID Incidente (formato NIS-yyy-####)	NIS-2026-0001
2	Data e ora T0 (conoscenza dell'evento, fuso CET)	12/05/2026 03:14
3	Data e ora di apertura formale	12/05/2026 04:00
4	Origine della segnalazione	Allerta SOC / utente interno / fornitore / esterno
5	Descrizione sintetica dell'evento	[testo libero, max 500 caratteri]
6	Sistemi/servizi impattati	LIS, RIS, PACS, Portale Refertazione, mail aziendale
7	Categoria (cfr. §3)	Es. Malware/ransomware
8	Significatività (Significativo / Grave / Non significativo)	Significativo
9	Motivazione di significatività	Riferimento ai criteri di art. 25 D.Lgs. 138/2024
10	Impatto su pazienti / dati clinici	[descrizione + n° pazienti coinvolti]
11	Impatto economico stimato	[€]
12	Impatto su SLA contrattuali	[Sì/No, dettaglio]
13	Owner interno (PdC NIS / IT Manager)	PdC NIS
14	T0+24h — Notifica preliminare CSIRT	Data/ora trasmissione + ID Portale ACN
15	T0+72h — Notifica intermedia CSIRT	Data/ora trasmissione + ID Portale ACN
16	T0+30gg — Relazione finale CSIRT	Data/ora trasmissione + ID Portale ACN
17	Data Breach GDPR (Sì/No, notifica Garante)	Sì — notificato al Garante il [data]
18	Comunicazione al pubblico/destinatari (art. 25 c. 5)	[Sì/No, motivazione e modalità]
19	Cause Root (RCA)	[5-Whys / Ishikawa, riferimento al fascicolo RCA]
20	Azioni correttive (CAPA) e relativi owner	[lista CAPA con scadenze]
21	Lessons Learned	[testo libero]
22	Stato (Aperto / In gestione / Chiuso)	Chiuso
23	Data chiusura formale	[data]
24	Riferimento al fascicolo evidenze	Path archivio digitale / SGI

5. Sezione di tracciatura incidenti — Anno corrente

Tabella sintetica aggiornata in tempo reale dal Punto di Contatto NIS, riepilogata in occasione del Riesame della Direzione e dell'audit annuale NIS2.

ID	Dat a T0	Categori a	Sistemi impattat i	Significativit à	T0+24 h	T0+72 h	T0+30g g	Stato
NIS-2026-0001	—	—	—	—	—	—	—	Nessun incidente significativo o registrato alla data di emissione del registro

6. Indicatori di processo

KPI	Formula	Target
-----	---------	--------

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

TD-SGI-MOD181_00 · Rev. 00 · Registro degli Incidenti Significativi NIS2

Numero incidenti significativi/anno	Conteggio diretto	Riduzione anno-su-anno o stabile
Tempo medio di rilevazione (MTTD)	$\Sigma (T_{\text{detection}} - T_{\text{onset}}) / N$	≤ 24 ore
Tempo medio di contenimento (MTTC)	$\Sigma (T_{\text{containment}} - T_0) / N$	≤ 4 ore per incidenti significativi
Rispetto della finestra T0+24h al CSIRT	Notifiche entro 24h / N notifiche dovute	100%
Rispetto della finestra T0+72h	Notifiche entro 72h / N dovute	100%
Rispetto della finestra T0+30gg	Relazioni finali entro 30gg / N dovute	100%
Chiusura RCA + CAPA	Incidenti chiusi formalmente / N totali (90gg)	$\geq 90\%$

7. Storico delle revisioni

Rev.	Data	Descrizione	Redatto	Approvato
00	29/04/2026	Prima emissione del registro incidenti significativi NIS2 in attuazione di TD-SGI-PRO070_00 §6.	RS GI	AD